ABRACADABRA MONEY · SECURITY REVIEW

Abracadabra Money OFT Updates.

A security review of OFT Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Abracadabra Money	OFT Updates	Guardian	December 24 – December 30, 2024	December 30, 2024

§ 00

Contents.

12 pages: overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01 **Overview** P. 03

§ 02 **Confidence Ranking** P. 04

§ 03 **Scope & Classifications** P. 05

§ 04 **Findings** P. 06

Main Review · 4 findings P. 07

§ 05 **Disclaimer** P. 11

§ 06 **About Guardian** P. 12

§ 01

Overview.

Guardian reviewed OFT Updates across a single review round. The final report includes 4 Low findings.

AUDIT FIRM
Guardian

CLIENT
Abracadabra Money

PROJECT
OFT Updates

PREPARED BY
Guardian

AUDIT WINDOW
December 24 – December 30, 2024

FINAL REPORT
December 30, 2024

REPOSITORY
`https://github.com/Abracadabra-money/abracadabra-v2-oft`

METHODOLOGY
Smart contract · Manual · Main Review

MAIN REVIEW COMMIT
`c2ab43f6faf2`

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	**0**	0	0	0	0
High	**0**	0	0	0	0
Medium	**0**	0	0	0	0
Low	**4**	4	0	0	0
Informational	**0**	0	0	0	0
All severities	**4**	**4**	**0**	**0**	**0**

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed OFT Updates in `https://github.com/Abracadabra-money/abracadabra-v2-oft`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.
LIKELIHOOD · LOW	Unlikely to ever occur in production.

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in. Status is where each finding ended up; its own page says how.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	Missing Aggregator Checks	Warning	LOW	PENDING	p. 7
L-02	feeTo Assigned To Zero	Validation	LOW	PENDING	p. 8
L-03	Missing disableInitializers	Validation	LOW	PENDING	p. 9
L-04	Excess Ether Is Lost	Trapped Funds	LOW	PENDING	p. 10

LOW L-01

PENDING

Missing Aggregator Checks

CATEGORY	Warning
LOCATION	FeeHandler.sol: 57
REVIEW	Main Review

DESCRIPTION

In the `FeeHandler` contract the `latestAnswer` on the configured aggregator contract is queried without checking the latestRoundData result with the updated time. Furthermore for FeeHandlers on L2s with sequencers like Arbitrum there is no check to ensure that the sequencer is active.
This means the price used to denominate the native asset can be inaccurate beyond the allowed threshold if the aggregator feed is stale.
It may instead be better to fallback to the fixed native fee in instances where the oracle price has not been updated as expected.

RECOMMENDATION

Consider using the fixed native fee as a fallback in the event that the aggregator price is stale or the sequencer is down.

RESOLUTION

Status: Pending.

LOW L-02

PENDING

feeTo Assigned To Zero

CATEGORY	Validation
LOCATION	FeeHandler.sol: 90
REVIEW	Main Review

DESCRIPTION

In the `FeeHandler` contract the `feeTo` address may be assigned to the zero address in the `setFeeTo` function. However there is no check to see if the `feeTo` address is the zero address when sending the fee to the `feeTo` address in the `SenderWithFees._lzSend` function.

RECOMMENDATION

Consider either validating that the `feeTo` is not `address(0)` in the `setFeeTo` function or include logic to skip the fee handler fee if the `feeTo` is `address(0)` in the `SenderWithFees` contract.

RESOLUTION

Status: Pending.

LOW L-03

PENDING

Missing disableInitializers

CATEGORY	Validation
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

In the `AbraOFTAdapterUpgradeable` and `AbraOFTUpgradeable` contracts the constructors do not include calls to `_disableInitializers` to disable the initializer functions from being called on the implementation contract directly.
This is not a significant risk as the upgradeable contracts are not UUPS proxies, however it is a best practice to disable the initializers for upgradeable contracts.

RECOMMENDATION

Consider including a call to the `_disableInitializers` function in the constructor for the `AbraOFTAdapterUpgradeable` and `AbraOFTUpgradeable` contracts.

RESOLUTION

Status: Pending.

LOW L-04

PENDING

Excess Ether Is Lost

CATEGORY	Trapped Funds
LOCATION	SenderWithFees.sol: 19
REVIEW	Main Review

DESCRIPTION

The `_lzSend` function in the `OAppSenderUpgradeable` contract performs validation on the `msg.value` to ensure that it matches the provided `_fee.nativeFee` with the `_payNative` function.
This validation is however missing from the `_lzSend` implementation in the `SenderWithFees` contract.
As a result users may accidentally provide a `msg.value` that exceeds the `_fee.nativeFee` specified and this amount will be lost to the caller and credited to the next user who calls the `_lzSend` function.

RECOMMENDATION

Consider including the `_payNative` validation in the `_lzSend` function in the `SenderWithFees` contract.

RESOLUTION

Status: Pending.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

$45B+
DIGITAL ASSETS UNDER REVIEW

200+
ENGAGEMENTS COMPLETED

500+
CRITICAL & HIGH FINDINGS REPORTED

Reach us at audits@guardianaudits.com.